

Figure 1: Name resolution

Iterative queries are usually made by DNS servers while recursive queries are made by clients, which helps to reduce the burden of referral searches. From the security perspective, it is important to know the basics of DNS, such as, there can be multiple DNS servers in an organisation replicating their zone records to each other in order to maintain name resolution consistency. DNS data can be updated dynamically without needing any service to be restarted, and when a change is made on the master server, it triggers replication to partner servers automatically. The actual time required for replication is defined by the TTL of each record. In case of geographically dispersed DNS servers, this time period can be as long as a day, since all servers in the chain maintain their own cache to speed up replication.

DNS security attacks

It has been observed that systems administrators spend a lot of time designing security around applications, servers and other infrastructure components, but unfortunately tend to forget hardening DNS servers. Please refer to Figure 2, which shows possible hack points where the DNS can be vulnerable to attacks. By design, the DNS heavily relies on UDP, does not contain security by itself, and does not have foolproof built-in authentication—which makes it more susceptible to hacking than other network-based services. Let's look at a few very common DNS attacks.

DNS cache poisoning: This attack lets name resolution to be tweaked in two ways. In one method, the hacker installs a root-kit or a virus, which is intended to take control of the local DNS cache of the client. Once done, entries in the local DNS are altered to point to a different IP address. For example, if a browser tries to access <http://www.cnn.com/>, instead of getting the CNN IP address, it gets an IP set by the hackers' script, which is usually in the hackers' own Web farm, and hosts viruses or shows some derogatory information. In a different and more dangerous approach, the hacker attacks a DNS server and alters its local cache—so all servers using that DNS server for resolution end up at a wrong IP address, causing a wide system failure, apart from information loss or theft.

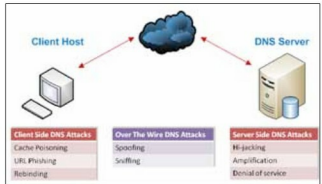


Figure 2: Possible attack points

In rare cases, hackers can access a root DNS server, which holds the base entries that form the root domain, such as www.iana.org/, www.icann.org/ or any country-specific name system. Hackers then modify entries on that server, which triggers automatic replication, and can cause serious global outages for multiple businesses and websites. Though such situations are rare, they have occurred—and that too, very recently, involving a famous social community chatting website.

DNS hijacking: This attack is also commonly used to bend the DNS system. Here, the client DNS cache on a client is not altered, but instead the client's DNS settings are changed to point to the hackers' own DNS server. Usually the purpose is not to steal data, but to gather statistical data from the client computer. All name resolution requests going to the hacker are resolved to the correct addresses, but the hacker learns of the typical sites visited by the client. This information can further be used by online advertisers to target that client with Web-visit-specific advertisements. Some ill-behaved e-thieves also redirect users to their own websites, or search engines, either to gain money from advertisements, or simply to steal data and use it for social engineering. While it is inappropriate to use this feature for any personal gain, it is being used by many well-known websites and ISPs to collect user browsing statistics.

DNS spoofing: This refers to merely a man-in-the-middle type of attack in which the hacker gains access to the network the DNS server is on, and performs ARP cache poisoning and spoofing on that network. Once MAC-level control is achieved, the hacker then fetches the IP address of the DNS server, and starts sniffing and spoofing requests meant for the real DNS server. The hacker's machine resolves all DNS queries, completely bypassing the real DNS server. This has serious consequences, because all machines on that network can be completely unaware of this, and end up sending DNS traffic to the hacker's machine.

There is an alternate method called DNS ID spoofing. Each DNS request and response carries a unique identifier, to differentiate between various simultaneously generated requests to a DNS server. This unique ID is usually a combination of the MAC address and the date/time stamp, and is created by the protocol stack automatically. A hacker uses a sniffer to look at one or more DNS requests and responds with